

Snort RAG PDF Upload Test - XSS KB Extension

Project-specific document for testing PDF-based knowledge-base extension in the Snort RAG dashboard.

Document role	Add focused XSS knowledge that can be retrieved during rule generation tests.
Project	Snort RAG Rule Generator - NLP + Retrieval-Augmented Generation for defensive Snort rule generation.
Use in dashboard	Upload this PDF in the PDF Upload tab to test temporary in-memory knowledge-base extension.
Version	Version 1 - XSS KB
Generated	2026-06-09

1. Attack family: Cross-Site Scripting (XSS)

This extension document adds project-specific knowledge about HTTP requests carrying XSS payloads. It is intended to be retrieved when the user asks for a Snort rule related to script tags, JavaScript event handlers, or encoded web payloads.

- Attack label: xss.
- Typical protocol: TCP over HTTP or HTTPS inspection after decoding by an HTTP-aware sensor.
- Main indicators: <script>, javascript:, onerror=, onload=, document.cookie, alert(1), encoded variants such as %3Cscript%3E.
- Recommended Snort options: msg, flow, http_uri or http_client_body when available, content, nocase, classtype, sid, rev.
- Rule goal: alert on suspicious script execution markers in client-to-server HTTP traffic.

2. Natural-language examples for retrieval

User description	Expected attack type	Important retrieval keywords
Detect XSS using script tag in a web request.	xss	xss, script tag, http uri, web request
A client sends %3Cscript%3Ealert(1)%3C/script%3E inside the URL.	xss	encoded script, alert(1), uri
Possible browser cookie theft using document.cookie in a parameter.	xss	document.cookie, cookie theft, parameter
JavaScript event handler onerror is submitted to the application.	xss	onerror, JavaScript event handler, web form

3. Snort-like rule template

The generated rule should remain simple, parseable, and grounded in retrieved examples. The exact SID can be assigned by the project generator.

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"KB XSS script tag in HTTP URI"; flow:to_server,established; ht
```

4. Example logs and false-positive context

Log example	Expected behavior
GET /search?q=%3Cscript%3Ealert(1)%3C/script%3E HTTP/1.1	Alert candidate because encoded script tag appears in a parameter.
POST /comment body=name=test&text=<script>alert(1)</script>	Alert candidate when body inspection is supported.
GET /docs/xss-prevention.html HTTP/1.1	Possible benign documentation page. Use URI and payload context carefully.
Normal HTTPS browsing and DNS lookup without payloads	No rule recommended. Do not create an alert for normal traffic.

5. Validation expectation

- The output must be syntactically Snort-like and contain a msg option, a detection condition, classtype, sid, and rev.
- The retrieval metadata should mention this PDF chunk as additional context if it is relevant.
- For benign traffic, the generator should prefer NO_RULE_RECOMMENDED instead of inventing a malicious alert.